

VM-1.2 DAST Vulnerabilities Threshold

Status: Draft

Control Objective

- Ensure that the company's people, processes, and technology systems are prepared to perform secure software development.
- Protecting all components of the company's software from tampering and unauthorized access.
- Producing well-secured software with minimal security vulnerabilities in its releases.
- Enforce a minimum number of DAST defects per system within the company.

Control Validation

- Software applications that are DAST-scannable, and scanned with the company's approved DAST scanning tool(s), must:
 - Provide scan evidence of deprecation of weak TLS 1.2 ciphers.
 - Contain no more than 0 Critical, 0 High, and 3 Medium vulnerabilities.
 - For applications with vulnerabilities outside of SLA, they must contain 0 Critical, High, or Medium vulnerabilities.
 - Use TLS 1.2 or greater.
 - Do not accept vulnerable ciphers such as:
 - NULL, RC2, RC4, DES, IDEA, 3DES
 - Use ECDHE key exchange.
 - Use CA certificates with at least 2048-bit RSA keys.
 - Use SHA-256 or stronger for hash algorithms for CA certificate signing.
 - Enable HTTP Strict Transport Security (HSTS).
 - Ensure that all cipher suites support Perfect Forward Secrecy (PFS).
- Software applications that are DAST-scannable, and scanned with the company's approved DAST scanning tool(s), should:
 - Prefer GCM over CBC as a cipher mode.
 - Accept some or all of the following ciphers:
 - TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
 - TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
 - TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
 - TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
 - TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256
 - TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256